

WEB SERVER TO HADOOP PIVOT

Validating source-observed connections from compromised web infrastructure to HiveServer2 and WebHDFS.

VALIDATION

CONFIDENCE: MEDIUM



REPORT DATE

29 July 2026

VERSION

v1.0

PRIMARY TELEMETRY

Defender XDR ·
DeviceNetworkEvents

ATT&CK

T1505.003 · T1059



EXECUTIVE ASSESSMENT

A narrow validation experiment derived from direct incident artifacts.

8.1 / 10

01

OPERATIONAL VALUE

Medium

02

ANALYTICAL CONFIDENCE

Validation

03

OPERATIONAL READINESS

SOURCE-CONFIRMED FACTS

- Recovered tooling opened HiveServer2 on TCP 10000.
- It registered a malicious Java UDF and passed commands through Hive SQL.
- Command output was retrieved through WebHDFS on TCP 50070.
- Researchers recommend alerting on web-server processes reaching these ports.

ANALYTICAL ASSESSMENT

Web-tier egress to an internal Hadoop control or data service is a strong architecture-dependent pivot. It requires authoritative asset inventories and local baseline before alerting.

Evidence boundary

A network event does not prove web-shell activity, Hive authentication, UDF creation, command execution or campaign attribution.

Detection hypothesis

If a compromised web server is used to pivot into Hadoop as documented, endpoint network telemetry should show the web-server host connecting to an inventoried Hadoop node on TCP 10000 or 50070. Legitimate overlap can be separated through asset role, initiating process, service account and approved application flow.

03

THREAT MECHANICS

Recovered attack tooling and the observable network boundary.

01 · WEB ACCESS

PHP/JSP web-shell artifacts were staged against web infrastructure.

02 · HIVE SESSION

Raw socket to internal HiveServer2 on TCP 10000 using SASL PLAIN.

03 · UDF EXECUTION

Malicious Java UDF carries shell commands through Hive SQL.

04 · OUTPUT

Command results are retrieved through WebHDFS on TCP 50070.

STAGE	DIRECT EVIDENCE	SELECTED TELEMETRY	DETECTION VALUE
Web shell	PHP shell at a source-observed web path	Not established by network event alone	Context only
Hive connection	Raw TCP socket to port 10000	Source/destination host, port and process	Primary signal
UDF execution	HiveCmd.jar and Hive SQL commands	Requires HiveServer2 audit logs	Corroboration
WebHDFS output	Second internal node on port 50070	Source/destination host, port and process	Primary signal

Unconfirmed elements

Initial access was unknown. Successful GlassFish deployment, data exfiltration and the exact web-server initiating process were not confirmed in the public report.

04

TELEMETRY AND EVIDENCE MODEL

Documented fields, required inventories and visibility gaps.

Microsoft Defender XDR - DeviceNetworkEvents

FIELD/CONTROL	RELIABILITY	PURPOSE	LEVEL
DeviceName, DeviceId	Documented	Attribute connection to web server	Required
RemoteIP, RemotePort	Documented	Identify Hadoop node and service	Required
Web/Hadoop inventories	Environment-dependent	Constrain architecture and benign overlap	Required
InitiatingProcessFileName	Documented; population-dependent	Identify network-originating process	Enrichment
InitiatingProcessCommandLine, SHA1	Documented; population-dependent	Process triage	Enrichment
ReportId + device + time	Documented	Unique event investigation key	Required

DATA REQUIREMENTS

- MDE coverage on every inventoried web server.
- Current web-tier and Hadoop IP inventories.
- File/process and network telemetry retention.
- In-portal confirmation of ActionType semantics.

UNAVAILABLE HERE

- Hive authentication result.
- UDF registration or Hive SQL content.
- Web-shell request parameter and command.
- WebHDFS response data or exfiltration proof.

05

PRIMARY VALIDATION LOGIC

Inventory-bound KQL with no inferred process-name filter.

KQL · VALIDATION

```
// Validation query - Untested implementation sketch
let WebServerDevices = dynamic(["<WEB_SERVER_FQDN>"]);
let HadoopNodeIPs = dynamic(["<HADOOP_NODE_IP>"]);
DeviceNetworkEvents
| where DeviceName in~ (WebServerDevices)
| where RemoteIP in (HadoopNodeIPs)
| where RemotePort in (10000, 50070)
| project Timestamp, DeviceId, DeviceName, LocalIP,
    RemoteIP, RemotePort, RemoteUrl, Protocol, ActionType,
    InitiatingProcessFileName, InitiatingProcessCommandLine,
    InitiatingProcessAccountName, InitiatingProcessSHA1, ReportId
| order by Timestamp desc
```

CONDITION	EVIDENCE	RATIONALE
Web-server inventory	Source describes compromised web infrastructure	Environment control; avoids inventing process names
Hadoop-node inventory	Target-specific internal Hadoop nodes	Prevents generic port-only matching
Ports 10000/50070	Directly present in recovered tooling	HiveServer2 and WebHDFS pivots

What a match means

An inventoried web server initiated traffic to an inventoried Hadoop node on a source-observed service port.

What it does not prove

Web shell, successful authentication, UDF execution, data access, exfiltration or attribution.



TRIAGE AND INVESTIGATION

Resolve architecture, application intent and execution evidence.

1 · VALIDATE ASSETS
Confirm source is an approved web server and destination is the intended Hadoop node.

2 · IDENTIFY PROCESS
Review executable, command line, account, signer, hash and parent process.

3 · CHECK SERVICE LOGS
Review HiveServer2 authentication, OpenSession, UDF registration, SQL and WebHDFS access.

4 · INSPECT WEB TIER
Search web roots, access logs and EDR for unexpected PHP/JSP files and command execution.

OUTCOME	MINIMUM EVIDENCE	ACTION
Benign	Approved application flow, expected process/account and known change	Document narrowly
Suspicious	Unexpected process, account, source host or timing	Acquire logs and file artifacts
Likely malicious	Web-shell evidence plus Hive UDF/command activity	Contain web server and Hadoop credentials
Insufficient	Missing asset inventory, process fields or service logs	Retain event; close unresolved

07

FALSE POSITIVES AND VALIDATION

Inventory quality and legitimate architecture determine usability.

BENIGN SCENARIO	LIKELIHOOD	IMPACT	TUNING ACTION
Approved web application queries Hive	Environment-dependent	High	Document exact app, process, account and destination
Monitoring or backup service	Low-Medium	Moderate	Validate software identity and service purpose
Incomplete asset inventory	Medium	False positives/negatives	Reconcile CMDB, EDR and Hadoop configuration
Missing process attribution	Environment-dependent	Weak triage	Test MDE telemetry on each server build

VALIDATION STEPS

1. Populate authoritative web-server and Hadoop-node inventories.
2. Generate controlled connections to both service ports.
3. Confirm process, command line, account and ReportId fields.
4. Review 30-90 days and classify every legitimate flow.

DECISION CRITERIA

Success: complete coverage and only approved flows or low unexplained volume.

Rejection: architecture permits broad expected web-to-Hadoop traffic.

Failure: inventories or MDE network events are incomplete.

Promotion gate

Promote only when local baseline shows low overlap and unexplained matches can be enriched with stable process/account signals or corroborated HiveServer2 and web-tier events.



ATT&CK, CONCLUSION AND REFERENCES

Coverage statement, residual risk and source control.

TECHNIQUE	NAME	DIRECT SUPPORT	COVERAGE
T1505.003	Web Shell	Source-observed PHP/JSP shell artifacts	Context only; not proven by query
T1059	Command and Scripting Interpreter	Commands issued through malicious Hive UDF	Network prerequisite only

ANALYST CONCLUSION

The web-to-Hadoop pivot is directly documented and operationally meaningful, but network telemetry observes only its prerequisite. The correct first implementation is inventory-bound validation, not a production alert or campaign attribution rule.

RESIDUAL RISK

- Alternate Hadoop ports bypass the query.
- A proxy or broker process may obscure origin.
- Inventory drift causes false negatives.
- Network activity does not reveal SQL or UDF content.

REFERENCES

1. Hunt.io and Bob Diachenko, "Thailand's Ministry of Finance Targeted With Hermes AI Agent Running Unattended, Hades Implant Staged," 23 Jul 2026.
[hxxps://hunt\[.\]io/blog/thailand-ministry-finance-targeted-with-hermes-ai-agent](#)
2. Microsoft Learn, "DeviceNetworkEvents table," updated 22 Jun 2026.
[hxxps://learn\[.\]microsoft\[.\]com/en-us/defender-xdr/advanced-hunting-devicenetworkevents-table](#)
3. MITRE ATT&CK T1505.003 and T1059.
[hxxps://attack\[.\]mitre\[.\]org/techniques/T1505/003/](#)

Document control

Version 1.0 · 29 Jul 2026 · Status: Validation · Confidence: Medium · Owner: Detection Engineering · No customer data or private indicators.